

OWASP ZAP - Instalação e Configuração

DAST e análise de segurança de aplicações Web em ambientes autorizados.

Objetivo deste manual

Este manual foi desenvolvido para orientar você por todo o processo de instalação e configuração da ferramenta, desde a preparação do ambiente até a validação final. Siga as etapas na ordem apresentada e utilize as verificações indicadas ao longo do guia para confirmar que cada configuração foi concluída corretamente.

Antes de começar

Java quando exigido pela distribuição e um ambiente de teste autorizado. Use somente contra sistemas que você tem permissão para testar.

Onde executar os comandos

No Windows, use PowerShell ou Prompt de Comando; no macOS/Linux, use Terminal. Sempre que PATH ou variáveis forem alterados, feche e abra um novo terminal antes de validar novamente.

Referências oficiais

<https://www.zaproxy.org/download/>

Instalação e configuração passo a passo

1. Baixe OWASP ZAP do site oficial para seu SO.
2. Execute o instalador/pacote e inicie ZAP.
3. Escolha persistência de sessão conforme seu laboratório.
4. Configure o browser para usar o proxy do ZAP ou use o browser lançado pelo próprio ZAP.
5. Acesse uma aplicação de laboratório e confirme que as requisições aparecem no histórico.
6. Para HTTPS, instale/confie o certificado apenas no ambiente de teste e remova quando não precisar.
7. Execute passive scan primeiro; use active scan somente com autorização explícita.

Primeiro uso funcional

A instalação está funcional quando ZAP captura tráfego de uma aplicação de laboratório.

Problemas comuns e como resolver

Nenhum tráfego: revise proxy/browser/porta.

HTTPS com erro: configure o certificado de teste corretamente; não desative validação global.

Active Scan pode alterar/atacar o alvo: nunca use sem autorização.

Critério de conclusão



Considere a configuração concluída quando as validações de versão/execução funcionarem e o primeiro uso deste próprio manual terminar sem erro. Só depois avance para integrações ou configurações mais complexas.